

WebPwn Advanced Pentest Report

Target: https://juiceshop.akto.io/

Date: 2026-05-25 19:16 | Generated by WebPwn Senior Pentest Module

Executive Summary

This report presents the findings of an advanced automated security assessment against https://juiceshop.akto.io/. The assessment utilized senior-level heuristics to identify critical vulnerabilities across OWASP Top 10 categories. A total of 49 security findings were recorded.

Severity	Count
CRITICAL	12
HIGH	7
MEDIUM	7
LOW	1
INFO	24

Detailed Security Findings

#1 [CRITICAL] Admin Dashboard — No Authentication Required

Location: https://juiceshop.akto.io/admin

CVSS Score: 9.8

Technical Details: Admin dashboard at https://juiceshop.akto.io/admin is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#2 [CRITICAL] Admin Dashboard — No Authentication Required

Location: https://juiceshop.akto.io/administrator

CVSS Score: 9.8

Technical Details: Admin dashboard at https://juiceshop.akto.io/administrator is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#3 [CRITICAL] Admin Dashboard — No Authentication Required

Location: <https://juiceshop.akto.io/dashboard>

CVSS Score: 9.8

Technical Details: Admin dashboard at <https://juiceshop.akto.io/dashboard> is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#4 [CRITICAL] Admin Dashboard — No Authentication Required

Location: <https://juiceshop.akto.io/wp-admin>

CVSS Score: 9.8

Technical Details: Admin dashboard at <https://juiceshop.akto.io/wp-admin> is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#5 [CRITICAL] Admin Dashboard — No Authentication Required

Location: <https://juiceshop.akto.io/manager>

CVSS Score: 9.8

Technical Details: Admin dashboard at <https://juiceshop.akto.io/manager> is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#6 [CRITICAL] Admin Dashboard — No Authentication Required

Location: <https://juiceshop.akto.io/cpanel>

CVSS Score: 9.8

Technical Details: Admin dashboard at <https://juiceshop.akto.io/cpanel> is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication on all admin routes. Use IP allowlisting for admin access if possible.

#7 [CRITICAL] XSS — Session Hijack Payload (Generated)

Location: <https://juiceshop.akto.io>

CVSS Score: 9.3

Technical Details: XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

#8 [CRITICAL] RCE — Remote Code Execution (Exploited)

Location: <https://juiceshop.akto.io>

CVSS Score: 10.0

Technical Details: Command 'id; whoami' executed. Output detected: 'root'

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

CRITICAL: Sanitize all shell inputs. Use subprocess with argument lists. Restrict OS command access from web layer.

#9 [CRITICAL] 2FA — Step Skip (Direct URL Access)

Location: <https://juiceshop.akto.io/dashboard>

CVSS Score: 9.1

Technical Details: Protected page '/dashboard' accessible without 2FA completion.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce 2FA completion check on ALL protected routes via Senior ware.

#10 [CRITICAL] 2FA — Cookie Bypass ('mfa_verified=true')

Location: <https://juiceshop.akto.io/dashboard>

CVSS Score: 9.8

Technical Details: Setting cookie `mfa_verified=true` bypasses 2FA entirely.

[!] Attacker Impact / Scenario:

Missing secure cookie flags allow attackers to steal session tokens via Cross-Site Scripting (XSS) or Man-in-the-Senior (MitM) attacks, leading to complete account takeover.

[+] Strategic Remediation:

Set 'HttpOnly', 'Secure', and 'SameSite=Strict' attributes on all sensitive cookies. Ensure the application enforces HTTPS strictly.

#11 [CRITICAL] CHAIN: JWT None Algorithm → Admin Privilege Escalation

Location: <https://juiceshop.akto.io>

CVSS Score: 9.8

Technical Details: JWT with 'alg:none' or weak HS256 secret allows forging tokens with arbitrary claims (e.g. `role:admin`). This bypasses all role-based access controls.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce RS256/ES256 algorithms. Reject 'none' algorithm. Validate all JWT claims server-side. Use short expiration times.

#12 [HIGH] GCP Bucket

Location: <https://storage.googleapis.com/juiceshop-backup>

CVSS Score: N/A

Technical Details: GCP Bucket status: Open — <https://storage.googleapis.com/juiceshop-backup>

[!] Attacker Impact / Scenario:

Accessible backup files can expose full database dumps, source code, credentials, and configuration secrets. This is a critical data exposure risk.

[+] Strategic Remediation:

Remove all backup files from the web root. Store backups in a secure, non-public storage location with access controls.

#13 [HIGH] Missing Header: Content-Security-Policy

Location: <https://juiceshop.akto.io>

CVSS Score: 7.5

Technical Details: CSP prevents XSS and data injection attacks by controlling allowed resource sources.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#14 [HIGH] Missing Header: Strict-Transport-Security

Location: <https://juiceshop.akto.io>

CVSS Score: 7.5

Technical Details: HSTS forces HTTPS connections and prevents SSL-stripping attacks.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#15 [HIGH] 2FA — No Rate Limiting on OTP (Brute-force Possible)

Location: <https://juiceshop.akto.io/>

CVSS Score: 7.5

Technical Details: Tested 7 OTP codes with no lockout or 429 response.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce max 5 attempts. Add exponential backoff and account lockout.

#16 [HIGH] 2FA — Remember-Me Cookie Forgery ('remember_me')

Location: <https://juiceshop.akto.io/dashboard>

CVSS Score: 7.5

Technical Details: Forged 'remember_me=1' cookie bypasses 2FA for trusted device.

[!] Attacker Impact / Scenario:

Missing secure cookie flags allow attackers to steal session tokens via Cross-Site Scripting (XSS) or Man-in-the-Senior (MitM) attacks, leading to complete account takeover.

[+] Strategic Remediation:

Set 'HttpOnly', 'Secure', and 'SameSite=Strict' attributes on all sensitive cookies. Ensure the application enforces HTTPS strictly.

#17 [HIGH] 2FA — OAuth/SSO May Bypass 2FA

Location: <https://juiceshop.akto.io/auth/google>

CVSS Score: 7.8

Technical Details: OAuth/SSO endpoint at '/auth/google' may log users in without 2FA. Social login commonly bypasses MFA if not explicitly enforced.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce 2FA for OAuth-authenticated users. Check MFA status post-OAuth login.

#18 [HIGH] CHAIN: CORS Misconfiguration → XSS → Session Theft

Location: <https://juiceshop.akto.io>

CVSS Score: 8.8

Technical Details: Permissive CORS allows malicious origins to make authenticated API requests. Combined with XSS, attacker can send victim's session cookies to a controlled server via cross-origin fetch.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict CORS to trusted origins. Do not use wildcard (*) with credentials. Set HttpOnly + Secure + SameSite on cookies.

#19 [MEDIUM] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/api-docs/>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#20 [MEDIUM] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/robots.txt>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#21 [MEDIUM] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/.well-known>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#22 [MEDIUM] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/security.txt>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#23 [MEDIUM] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/metrics>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#24 [MEDIUM] CORS Wildcard Origin

Location: https://juiceshop.akto.io

CVSS Score: 5.3

Technical Details: Server returns Access-Control-Allow-Origin: * — any origin can read responses.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Restrict ACAO to a specific trusted origin. Never use wildcard when credentials are involved.

#25 [MEDIUM] 2FA — Not Implemented

Location: https://juiceshop.akto.io

CVSS Score: 5.9

Technical Details: No 2FA/MFA endpoint detected.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Implement TOTP-based 2FA (FIDO2/WebAuthn/RFC 6238) for all accounts.

#26 [LOW] Missing Header: Referrer-Policy

Location: https://juiceshop.akto.io

CVSS Score: 3.1

Technical Details: Missing Referrer-Policy may leak sensitive URL information to third parties.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#27 [INFO] Technology Fingerprinting

Location: https://juiceshop.akto.io/

CVSS Score: N/A

Technical Details: Technology detected: Not disclosed

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#28 [INFO] Web Crawler

Location: <https://juiceshop.akto.io/>

CVSS Score: N/A

Technical Details: -

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#29 [INFO] AWS S3

Location: <http://juiceshop-staging.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://juiceshop-staging.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#30 [INFO] AWS S3

Location: <http://juiceshop.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://juiceshop.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#31 [INFO] Azure Blob

Location: <https://juiceshop.blob.core.windows.net/>

CVSS Score: N/A

Technical Details: Azure Blob status: Exists — <https://juiceshop.blob.core.windows.net/>

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#32 [INFO] GCP Bucket

Location: <https://storage.googleapis.com/juiceshoptest>

CVSS Score: N/A

Technical Details: GCP Bucket status: Exists (Access Denied) — <https://storage.googleapis.com/juiceshoptest>

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#33 [INFO] Infrastructure

Location: <https://juiceshop.akto.io/>

CVSS Score: N/A

Technical Details: Company: 13.64.0.0/11

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#34 [INFO] IP Prefixes

Location: <https://juiceshop.akto.io/>

CVSS Score: N/A

Technical Details: 208.66.231.0/24, 51.140.0.0/14, 128.24.0.0/16, 199.65.40.0/24, 137.117.0.0/16, 135.130.0.0/16, 204.194.56.0/22, 2001:df0:d8::/48, 134.170.0.0/16, 135.88.0.0/16...

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#35 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/api-docs>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#36 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/media>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#37 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/assets>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#38 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/api/>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#39 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/api/v2/>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#40 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/rest>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#41 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/api/v1>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#42 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/profile>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#43 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/api/v3>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#44 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/api/v1/>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#45 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/api>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#46 [INFO] Exposed Sensitive Path

Location: <https://juiceshop.akto.io/api/v2>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#47 [INFO] Missing Header: Permissions-Policy

Location: <https://juiceshop.akto.io>

CVSS Score: 2.0

Technical Details: Missing Permissions-Policy allows access to powerful browser APIs (camera, mic, etc.).

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#48 [INFO] Missing Header: Cross-Origin-Opener-Policy

Location: <https://juiceshop.akto.io>

CVSS Score: 2.0

Technical Details: Missing COOP allows cross-origin pages to access window references.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#49 [INFO] Missing Header: Cross-Origin-Resource-Policy

Location: <https://juiceshop.akto.io>

CVSS Score: 2.0

Technical Details: Missing CORP allows cross-origin pages to load this site's resources.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).
